

6.

THE PCI DSS SCOPE

What is the “scope” of PCI DSS compliance, and how does it affect us?



FUNDAMENTALS

FUNDAMENTALS **THE PCI DSS SCOPE**

The concept of the “scope” of PCI DSS seems simple. If it touches card data, it must comply with PCI DSS, and if not, it doesn’t. However, it goes a little bit deeper than that. We can define three main groups of systems:

- The CDE
 - Systems and components that directly interact with card data, or have unrestricted connectivity to them;
- Connected Systems / Security-Impacting Systems
 - Systems that directly connect to the CDE, provide security to the CDE, indirectly connect, or similar;
- Out-of-Scope Systems
 - Systems that don’t connect/interact w/ CDE in any way;
 - The only group that does not need to comply;

FUNDAMENTALS

THE PCI DSS SCOPE

The first group is the CDE itself:

- This includes any system or component that directly deals with card data, such as the networks where card data are transmitted, or databases where card data are stored;
- They either store, process or transmit card data (regardless of whether it's CHD or SAD);
- It also includes other systems that are in the same network as, or have unrestricted connectivity to, systems in the CDE;
 - Even if a system would technically not be in the CDE, if it can access everything that a system in the CDE would, then, in practice, it's in the CDE, so it's designated that way;





FUNDAMENTALS

FUNDAMENTALS **THE PCI DSS SCOPE**

Then, we have Connected-to or Security-Impacting Systems:

- These systems are, by definition, not in the CDE, but they impact the CDE through their connections or working;
 - For example, an IDS/IPS system may not be in the CDE (it may be “outside”, protecting it, but for all intents and purposes, any failure or compromise of the IDS/IPS system will also occur to the CDE);
- Categories include:
 - Systems directly or indirectly connecting to the CDE;
 - Systems that impact configurations/security of the CDE;
 - Systems that provide security to the CDE;
 - Systems that segment the CDE from the outside;
- These must also comply with the PCI DSS;

FUNDAMENTALS

THE PCI DSS SCOPE

Finally, we have Out-of-Scope Systems:

- These are systems, that, put simply, do not interact or influence the CDE in any way;
- Imagine a coffee shop that has an internal WiFi that is used to process transactions;
 - It has another public Wi-Fi that uses different security systems, configurations, and does not impact our internal Wi-Fi in any way. It's considered Out of Scope;

The criteria are:

- None of the previous category (cannot connect to the CDE in anyway, impact security or configurations, etc);
- Cannot store, process or transmit card data, and cannot be in the same subnet/VLAN as systems that perform this;



FUNDAMENTALS

THE PCI DSS SCOPE

EXAMPLES

/01 SCOPE REDUCTION

Practically all complying companies seek to reduce their scope. The less systems that comply with PCI DSS, the less documentation, strict controls, etc.

/02 SEGMENTATION

A good practice for reducing scope is segmentation. Instead of making your entire network PCI DSS compliant, the CDE network is segmented.

/03 A TRADE-OFF

Separating systems from the CDE sometimes means purchasing equipment, hiring more people, or added costs. But you also save in reduced PCI DSS activity.

FUNDAMENTALS

THE PCI DSS SCOPE

KEY TAKEAWAYS

/01 THE CDE

Systems and networks that store, process or transmit card data. Also, those with unrestricted access, or a shared network with, those that do. Must comply.

/02 CONNECTED/SECURITY

Connected systems or security-impacting systems either connect to the CDE or impact its security or configuration in some way. They must comply, too.

/03 OUT OF SCOPE

All other systems that do not deal with card data, do connect/impact the security of those that do, and do not share subnets/VLANs with them. Must not comply.